Informe de Penetración - Máquina "Lo-Fi"

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.65.154.115
Fecha del Test	15 de marzo de 2026
Consultor	Bender2997_

1. Resumen Ejecutivo

El objetivo de esta evaluación fue la dirección IP 10.65.154.115, identificada como la máquina "Lo-Fi", para validar la existencia de vectores de compromiso.

Se identificó y explotó una vulnerabilidad crítica de Inclusión de Archivo Local (LFI) en el servidor web. El sistema estaba configurado con una lista de bloqueo básica que fue evadida mediante una técnica de *path traversal* (recorrido de rutas) utilizando la herramienta Gobuster y un diccionario de *fuzzing* específico. Este proceso permitió el acceso a archivos sensibles del sistema operativo. La criticidad de este hallazgo se clasifica como Crítica, ya que una explotación exitosa de LFI puede conducir a la lectura de información confidencial del sistema, e incluso a la ejecución remota de código bajo ciertas configuraciones.

2. Metodología y Alcance

Campo	Objetivo	Detalle
Entorno	Servidor Web "Lo-Fi"	IP Objetivo 10.65.154.115
Alcance	Pruebas de caja negra (Black-Box)	Limitadas a la identificación y explotación de una única vulnerabilidad crítica.

Metodología		Se siguió un enfoque iterativo: reconocimiento de puertos, pruebas iniciales de LFI, y *fuzzing* avanzado con Gobuster para evadir los filtros de seguridad.

3. Fase de Reconocimiento y Descubrimiento

Se realizó un escaneo de puertos TCP a la IP objetivo para identificar la superficie de ataque.

Comando Nmap utilizado:

nmap -T5 -sS -sCV -Pn -n -p- --open 10.65.154.115

Resultados del Escaneo:

Puerto	**Estado**	**Servicio**	**Versión**
22/tcp	Abierto	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (protocol 2.0)
80/tcp	Abierto	http	Apache httpd 2.2.22 ((Ubuntu))

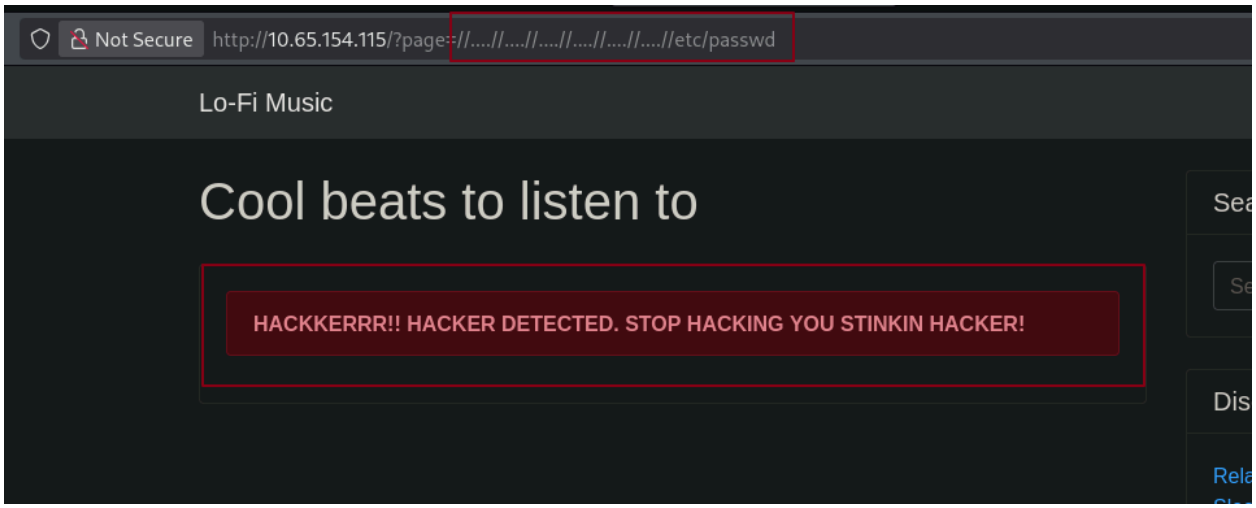
Análisis de Servicios:

El servidor web en el puerto 80 corría **Apache httpd 2.2.22** y su título de página era **"Lo-Fi Music"**. Se procedió a probar la existencia de la vulnerabilidad de Inclusión de Archivo Local (LFI) mediante la inyección de rutas para acceder al archivo /etc/passwd.4. Hallazgo: Inclusión de Archivo Local (LFI) - Evasión de Filtro

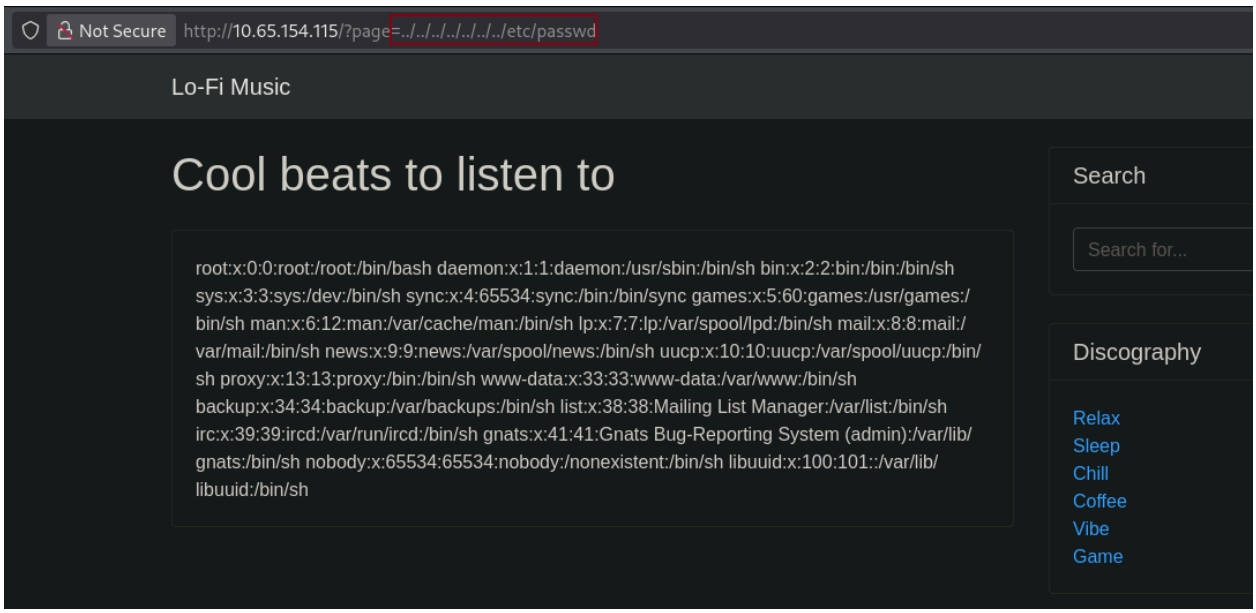
ID	**LVF-001**
Severidad	Crítica (High)
CWE	CWE-22 (Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'))

Descripción de la Vulnerabilidad:

El parámetro de la aplicación web susceptible a LFI inicialmente bloqueaba las secuencias de *path traversal* (../). Un intento inicial de LFI con rutas excesivas fue detectado y bloqueado, devolviendo el mensaje: "HACKKERRR!! HACKER DETECTED. STOP HACKING YOU STINKIN HACKER!".



Sin embargo, el *fuzzing* de rutas con la herramienta Gobuster permitió descubrir una secuencia de *path traversal* válida que evadió el filtro de seguridad.



Impacto:

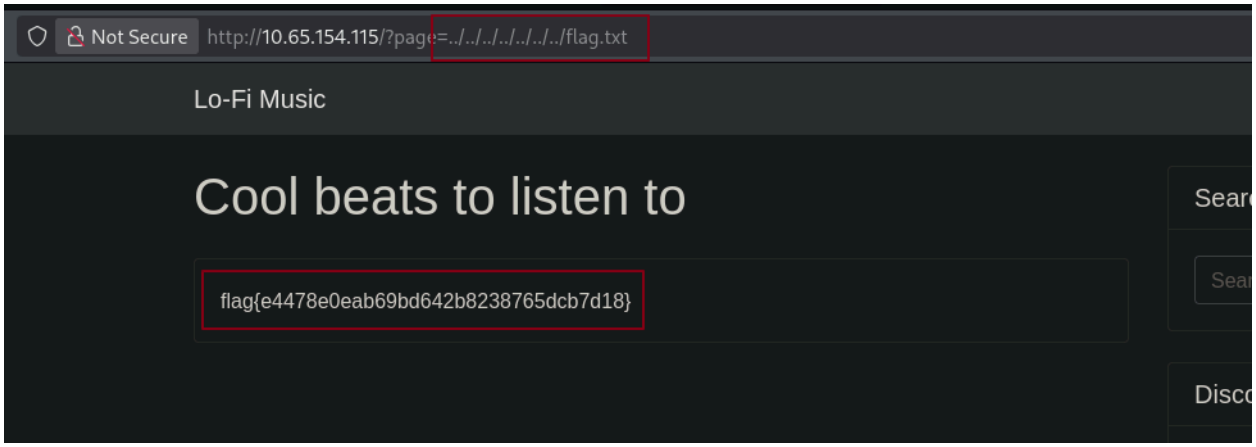
La explotación exitosa de la vulnerabilidad de LFI permite a un atacante no autenticado leer archivos sensibles del sistema operativo, como /etc/passwd, lo que expone información sobre las cuentas de usuario. Este acceso a información sensible

representa un riesgo directo para la confidencialidad del sistema y puede ser un paso inicial para la escalada de privilegios o la obtención de acceso remoto.

Prueba de Concepto (PoC):

1. **Intento Inicial Fallido (Bloqueado):**
   http://10.65.154.115/?page=//..../..../..../..../..../..../etc/passwd
2. **Fuzzing para Evasión de Filtro:**
   Se utilizó Gobuster con un diccionario de *path traversal* para encontrar el valor correcto:
   gobuster dir -u 10.65.154.115 -w /usr/share/wordlists/seclists/Fuzzing/LFI/LFI-LFISuite-pathtotest-huge.txt -t 100 -n --hl 305
3. **Valor de *Path Traversal* Correcto:**
   La herramienta identificó la ruta válida: ../../../../../../../etc/passwd
4. **Acceso Exitoso y Obtención de *Flag*:**
   La explotación con la ruta correcta condujo a la validación del compromiso del sistema.

Flag Obtenida (Indicador de Compromiso):
Flag{e4478e0eab69bd642b8238765dcb7d18}



5. Conclusiones y Recomendaciones de Mitigación

Conclusión:

La prueba de penetración demostró una falla crítica en la validación de la entrada del usuario en el parámetro de la aplicación web. Aunque existía un mecanismo de defensa (lista de bloqueo de caracteres), este fue ineficaz ante técnicas de *fuzzing* avanzadas, lo que permitió la Inclusión de Archivo Local y el compromiso del sistema.

Recomendaciones Críticas (LVF-001):

1. **Principio de Mínimo Privilegio (Prioridad Crítica):**
    - **Eliminar la funcionalidad de LFI/Path Traversal:** Se debe rediseñar la aplicación para evitar el uso de entradas de usuario para incluir archivos directamente.
    - **Lista Blanca vs. Lista Negra:** Implementar un mecanismo de **Lista Blanca** estricto, que solo permita un conjunto de nombres de archivo y/o directorios definidos y seguros. Nunca depender únicamente de una lista negra para filtrar secuencias maliciosas.
2. **Validación Robusta de Entradas (Prioridad Alta):**
    - Asegurar que todas las entradas del usuario se validen estrictamente. Esto incluye sanitizar la entrada, eliminando caracteres de secuencia de ruta (. y /) antes de que el valor se utilice en cualquier operación de archivo o ruta.
3. **Hardening del Sistema (Prioridad Media):**
    - Asegurar que el usuario de la aplicación web (por ejemplo, www-data o apache) tenga el menor número de privilegios posible y esté confinado a su propio directorio (chroot o contenedores) para limitar el alcance de cualquier explotación.